¿Qué ha ocurrido con PHP?

01 / PANORAMA | PHP2Shell: un problema del propio PHP que sostiene los sitios web

Riesgo de ataque incluso antes de iniciar sesión
El 21 de octubre de 2026, el equipo de PHP publicó correcciones para dos vulnerabilidades críticas. Si se dan ciertas condiciones, un atacante sin autenticar puede ejecutar código no autorizado en el servidor.

¿Qué es PHP?
Lenguaje de programación del servidor usado por WordPress y otros sistemas. Genera páginas y procesa los datos introducidos.

CVE-2026-109618
El tratamiento de la falta de memoria puede dejar datos internos incompletos; operaciones de memoria indebidas podrían permitir ejecutar código.

CVE-2026-109619
Puede persistir un estado interno antiguo relacionado con memoria liberada y usarse en una petición posterior, posibilitando la ejecución de código.

Ambas tienen una gravedad de 9.2 / 10
“Crítica” en CVSS v4.0. El éxito real del ataque también depende de la configuración y los ajustes.

Reforzar solo la contraseña de administración no resuelve el problema de raíz.
TODOROKI / CIBERSEGURIDAD / 2026.10.23

¿Cuáles son los riesgos?

02 / RIESGO | El daño depende de los permisos de PHP y de la información accesible

01 Filtración de información
Podrían robarse ajustes del servidor, credenciales e información de bases de datos accesibles.

02 Manipulación del sitio
Modificar páginas o enlaces e instalar formularios falsos también podría perjudicar a los usuarios.

03 Interrupción del servicio e intrusión persistente
Obstaculizar procesos o instalar archivos maliciosos podría detener la actividad o permitir nuevas intrusiones.

No afecta solo a WordPress
PHP advierte ampliamente sobre los entornos que procesan peticiones web, incluidos PHP-FPM, mod_php de Apache, php-cgi, FrankenPHP y LiteSpeed.

En particular, existen demostraciones en mod_php de ataques que funcionan antes de ejecutarse el código de la aplicación. Una pantalla de inicio de sesión no basta para confiarse.

Son daños posibles; no significa que todos los sitios estén comprometidos.
TODOROKI / CIBERSEGURIDAD / 2026.10.23

La solución de raíz: actualizar PHP

03 / ACTUALIZACIÓN | Comprobar por separado del núcleo de WordPress y sus complementos

Versiones que incorporan estas correcciones
PHP 8.2: 8.2.35
PHP 8.3: 8.3.36
PHP 8.4: 8.4.27
PHP 8.5: 8.5.12

Usar estas versiones corregidas o posteriores de la misma rama, o paquetes cuyo distribuidor haya aplicado los arreglos. No juzgar solo por la versión mostrada; consultar también el aviso del proveedor.

Comprobar → preservar → actualizar → inspeccionar
1. Consultar en el panel o al proveedor si se usa PHP y su estado de corrección.
2. Respaldar archivos y bases de datos y comprobar compatibilidad.
3. Actualizar PHP, reiniciar los procesos necesarios y buscar actualizaciones omitidas.
4. Revisar la visualización, el acceso, archivos y comunicaciones sospechosos.

El soporte ordinario de PHP 8.1 y anteriores ha finalizado. Consultar al distribuidor sobre las correcciones y avanzar hacia una rama con soporte.

En alojamiento compartido, preguntar: “¿Se han corregido estos dos CVE?”
TODOROKI / CIBERSEGURIDAD / 2026.10.23

¿Qué hacer si no se puede actualizar?

04 / ACCIÓN | Medidas temporales, respuesta a incidentes y acciones de los usuarios

No considerar seguras las medidas temporales por sí solas
Los cambios oficiales de ajustes reducen algunas vías de ataque, pero solo actualizar resuelve completamente el problema. Consultar al administrador y valorar restringir el acceso o detener temporalmente los servicios afectados.

No copiar valores de configuración sin evaluarlos
Desactivar el progreso de subida mitiga rutas concretas. Cambiar los límites de memoria puede afectar a la disponibilidad; evaluar todo el entorno.

Si se sospecha una intrusión, no terminar con la actualización
La versión corregida no elimina archivos maliciosos ya instalados. Preservar registros y pruebas e investigar el alcance. Si es necesario, restaurar desde un entorno seguro y cambiar credenciales.

Los usuarios deben consultar los avisos oficiales
Corresponde al operador corregir su servidor. Revisar las advertencias y dejar de introducir datos en pantallas de acceso o pago extrañas. Realizar los trámites anunciados desde la aplicación oficial o una web oficial conocida.

Que “se muestre normalmente” no demuestra seguridad.
TODOROKI / CIBERSEGURIDAD / 2026.10.23